

WIRELESS NETWORK AND IOT SECURITY

Lecture 9: Wired Equivalent Privacy (WEP)

Instructor: Kui Ren



Wi-Fi

- Wi-Fi is a wireless networking technology used across the globe.
- Wi-Fi refers to any system that uses the 802.11 standard, which was developed by the Institute of Electrical and Electronics Engineers (IEEE) and released in 1997.
- The term Wi-Fi, which is alternatively spelled WiFi, Wi-fi, Wifi, or wifi, was pushed by the **Wi-Fi Alliance**, a trade group that pioneered commercialization of the technology.



802.11

- 802.11 is a set of standards for wireless local area network (WLAN) computer communication, developed by the IEEE LAN/MAN Standards Committee (IEEE 802) in the 5 GHz and 2.4 GHz public spectrum bands.

TABLE 1: WLAN PHYSICAL LAYER EVOLUTION				
Year	Standard	Peak PHY rate (Mb/s) Including optional modes	Typical access point	Key technology
1997	802.11	2	2	Spread spectrum
1999	802.11b	11	11	CCK, spread spectrum
1999	802.11a	54	54	OFDM
2003	802.11g	54	54	OFDM
2009	802.11n	600	300-450	MIMO OFDM, wide bandwidth (40 MHz)
2013	802.11ac	6933	1300-3466	DL MU-MIMO, wide bandwidth (80 and 160 MHz)

Sensitive Information over Wi-Fi



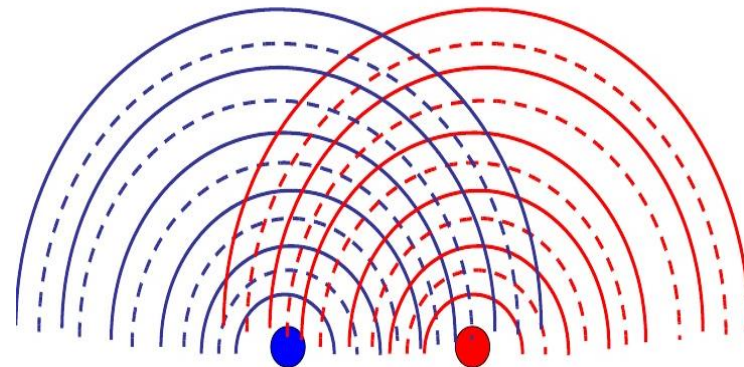
Why security is more of a concern in wireless?

- No inherent physical protection
 - Physical connections between devices are replaced by logical associations
 - Sending and receiving messages do not need physical access to the network infrastructure (cables, hubs, routers, etc.)



Why security is more of a concern in wireless?

- Broadcast communications
 - Wireless usually means radio, which has a broadcast nature
 - Transmissions can be overheard by anyone in range – anyone can generate transmissions,
 - which will be received by other devices in range
 - which will interfere with other nearby transmissions and may prevent their correct reception (jamming)



Why security is more of a concern in wireless?

- Eavesdropping is easy
- Injecting bogus messages into the network is easy
- Replaying previously recorded messages is easy
- Illegitimate access to the network and its services is easy
- Denial of service is easily achieved by jamming



Threats

- Wireless technology doesn't remove any old security issue
 - Eavesdropping
 - Man-in-the-middle attacks
 - Denial of Service



Eavesdropping

- Easy to perform, most impossible to detect
- By default , everything is transmitted in clear text
 - Username, passwords, content...
 - No security offered by the transmission medium
- Different tools available on the internet
 - Network sniffers, protocol analyzers
 - Password collectors
- With the right equipment, it's possible to eavesdrop traffic from few kilometers away



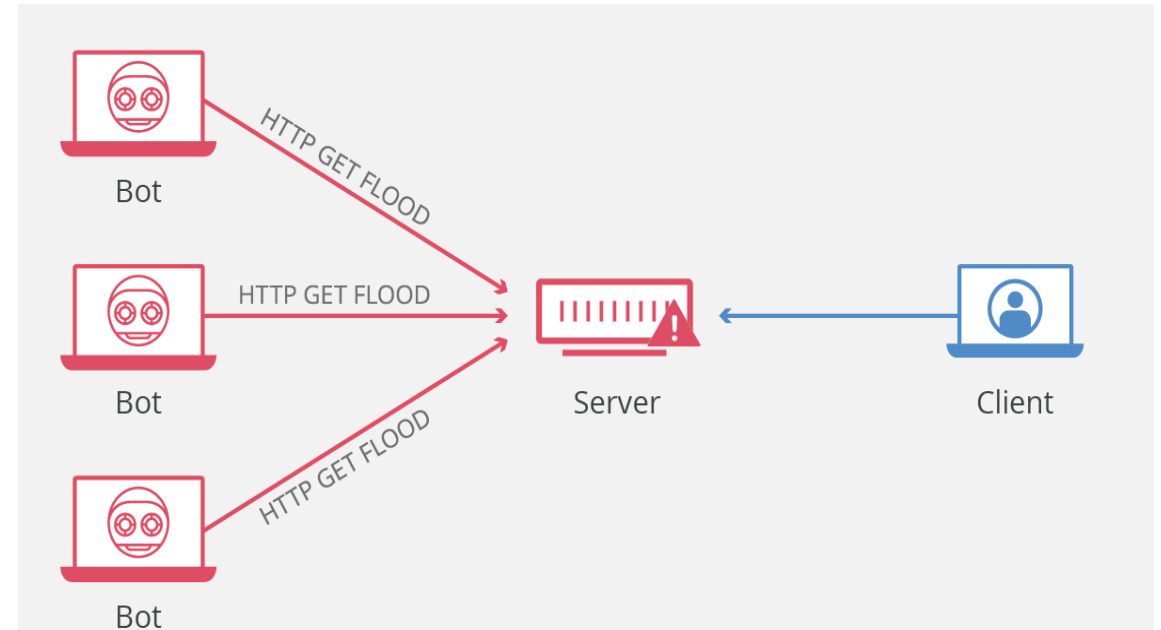
Man In The Middle Attack

- Attacker spoofs a disassociate message from the victim
- The victim starts to look for a new AP, and the attacker advertises his own AP on a different channel, using the real AP's MAC address
- The attacker connects to the real AP using victim's MAC address



Denial of Service

- Attack on transmission regency used
 - Frequency jamming
 - Not very technical, but works
- Attack on MAC layer
 - Spoofed disassociation messages
 - Can target on specific user
- Attacks on higher layer protocol (TCP/IP protocol)
 - SYN Flooding



Wireless Communication Security Requirements

- Confidentiality
- Authenticity
- Replay detection
- Integrity
- Access control
- Protection against jamming



Wi-Fi Security Protocols

- Wired Equivalent Privacy (WEP)
- Wi-Fi Protected Access (WPA)
- Wi-Fi Protected Access II (WPA2)



So what is WEP?

- WEP is Wired Equivalent Privacy
- Link-layer encryption
- Defined in the IEEE 802.11 standard
- Goals of WEP
 - Confidentiality
 - Access control
 - Data integrity
- Yet, WEP **failed** to achieve any of the above goals



WEP Flavors

- Uses RC4 (stream cipher) for encryption
 - A compromise of hardware costs, speed, and security
- Originally (1999) 64 bit (40 + 24):
 - 40 bit key
 - 24 bit Initialization Vector (IV)
- 128 bit (104 + 14):
 - 104 bit (13 ASCII characters, 26 Hex-Characters) key. $104 = 13 \times 8$.
 - 24 bit Initialization Vector (IV)
- 256 bit:
 - 232 bit key
 - Available, but not common

WEP Encryption: Players

- Message: What you're encrypting
- CRC: To verify the integrity of the message
- Plaintext: The message + CRC
- Initialization vector (IV): A 24-bit number which plays two roles that we'll meet in a moment
- Key: A 40 or 104-bit number which is used to build the keystream
- Keystream: What is used to encrypt the plaintext
- Ciphertext: What we end up post-encryption



WEP Encryption: Step by Step



Step 1: Compute CRC for the message

- CRC-32 polynomial is used



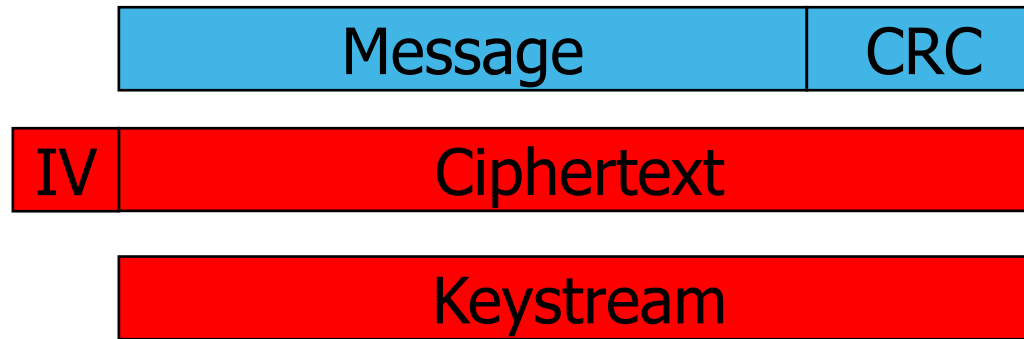
WEP Encryption: Step by Step

Keystream

Step 2: Compute the keystream

- IV is concatenated with the key
- RC4 encryption algorithm is used on the 64 or 128 bit concatenation

WEP Encryption: Step by Step



Step 3: Encrypt the plaintext

- The plaintext is XORed with the keystream to form the ciphertext
- The IV is prepended to the ciphertext

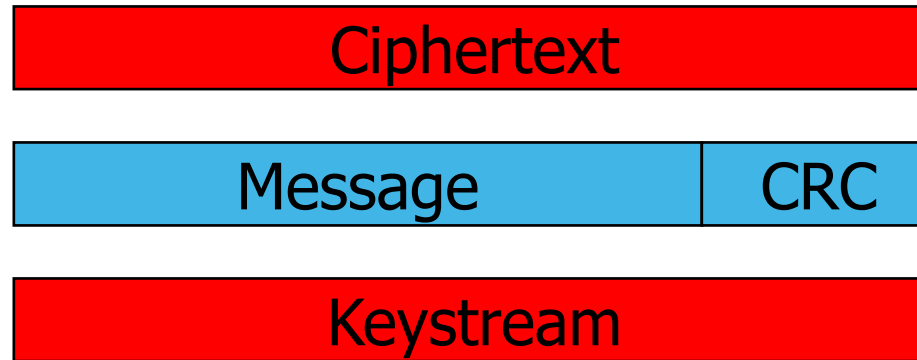
WEP Decryption: Step by Step



Step 1: Build the keystream

- Extract the IV from the incoming frame
- Prepend the IV to the key
- Use RC4 to build the keystream

WEP Decryption: Step by Step



Step 2: Decrypt the plaintext and verify

- XOR the keystream with the ciphertext
- Verify the extracted message with the CRC

Major Problems with WEP

- Borisov, et al. [1]:
 - Keystream (IV) reuse
 - Key management/distribution
 - Weak message authentication (ICV)
- Arbaugh, et al. [2]:
 - Shared key authentication
 - Can authenticate with AP without knowing the WEP key
 - But still don't know the WEP key, i.e. cannot access the network further

[1] Borisov, Nikita, Ian Goldberg, and David Wagner. "Intercepting mobile communications: the insecurity of 802.11." *Proceedings of the 7th annual international conference on Mobile computing and networking*. ACM, 2001.

[2] Arbaugh, W. A., Shankar, N., Wan, Y. J., & Zhang, K. (2002). Your 80211 wireless network has no clothes. *IEEE Wireless Communications*, 9(6), 44-51.



Keystreams

- The WEP seed is feed into PRNG to generate a keystream
 - WEP seed = 24-bit IV + fixed key
 - Then, the keystream is XOR'ed with the plaintext and checksum to produce the ciphertext.
- Whenever the same IV is used with the same master key,
 - the keystream will be the same as well.

A Stream-Cipher should never use the same key twice!



The Stream-Cipher-Breakdown

- $E(P1) = P1 \text{ xor } C$ [C is the key]
- $E(P2) = P2 \text{ xor } C$ [C is the same key]
- Since xor is commutative:
- $E(P1) \text{ xor } E(P2) = P1 \text{ xor } C \text{ xor } P2 \text{ xor } C$
- $\quad\quad\quad = P1 \text{ xor } P2 \text{ xor } C \text{ xor } C$
- $\quad\quad\quad = P1 \text{ xor } P2$

$$(P_1 \oplus C) \oplus (P_2 \oplus C) = P_1 \oplus P_2$$



Keystream Reuse/Collision

- Master keys are unlikely to be changed due to key management issues (more on this later...)
- 24 bits of IV are not sufficient to avoid collisions
 - Assuming 1500-byte packets at 11 Mbps, 2^{24} possible IVs will be exhausted in about 5 hours
 - If IVs are assigned randomly, collisions can be expected (50% probability) after 5000 packets (Birthday paradox).
 - If IVs are assigned sequentially, collisions are inevitable if cards are re-initialized (e.g., always start from zero)

Initialization vector (IV)

- It's carried in plaintext in the “encrypted” message!
- It's only 24 bits!
- There are no restrictions on IV reuse!
- The IV forms a significant portion of the “seed” for the RC4 algorithm!
 - It was discovered that it is easy to decrypt RC4 ciphertext if part of the key is known.

Weak IVs and Weak Keys in RC4

- It has been known for a while that RC4 has weak keys
 - Weak keys are more susceptible to showing the relationship between plaintext and ciphertext
- Weak IVs correspond to weak Keys.
 - Weak IVs have the following patterns:
 - First byte: range from 3 to 7
 - Second byte: 255
 - Third byte: anything
 - There are approx. 9000 weak IVs out of the 40 bit WEP secret keys. It is about 5% of total number IVs.

Weak Message Integrity (ICV)

- The ICV is generated from a cyclic redundancy check (CRC-32)
 - Only a simple arithmetic computation.
 - Can be done easily by anyone.
 - Not cryptographically secure.
- Easy for an attacker to change a packet and then change ICV to get response from AP.
 - E.g., replay attacks or injection attacks

Key Management

- WEP does NOT include any key management protocols!
 - Master keys could be one of four globally shared keys
- Key must be updated manually
 - Often, one key is relied on



WEP (Re)Keying in Practice

- Keys are manually distributed
- Keys are statically configured
 - Implications: often infrequently changed and easy to remember!
- Key values can be directly set as hex data
- Key generators provided for convenience
 - ASCII string is converted into keying material
 - Non-standard but in wide use

User Authentication

- Authentication is optional
- WEP uses a “Shared Key Authentication” protocol to authenticate stations
 - Initiator requests shared key authentication
 - Responder sends initiator random challenge text
 - Initiator sends responder encrypted challenge text
 - Responder signals successful completion of protocol
- This is supposed to prove that the initiator knows the correct key
- However, if a keystream is known, no key is necessary, so anybody can authenticate!

WEP Weakness Summary

- IV (key) reuse due to limited IV space
 - Known plaintext attack
 - Lots of known plaintext in IP, ICMP, ARP, and etc.
 - Partial known plaintext attack
 - e.g., the IP header
 - Possible to recover some portion of the keystream
 - Can extend partially recovered keystream to the entire keystream via repeated probing/trying
- Weak Integrity check (ICV)
 - Lack of IV replay protection (ARP replay attacks)
 - Possible to flip bits in real time, which is enabled by linearity of CRC32 (weak integrity check)



WEP Weakness Summary (Cont'd)

- No key management or exchange framework defined
- Loose authentication
 - Beacon messages are not authenticated
 - Enables station to roam to a rogue AP
 - Disassociate (also De-auth), re-associate messages not authenticated
 - Enables DoS attacks

Common Attacks on WEP

- The Brute Force / Dictionary Attack
- The FMS Attack
- The Chopchop Attack
- The Fragmentation Attack



Common Attacks: The Brute Force / Dictionary Attack

- “Power” of the WEP relies in the difficulty of discovery of the secret key through a brute-force attack
- “Dictionary attack” uses dictionary of keys, not all possible keys
- Such attack requires less than a month for all keys



The Brute Force / Dictionary Attack: Steps

1. Capture 2 WEP encrypted packets
2. Try to decrypt it using the captured IV and a potential key
3. Verify decrypted ICV (the CRC)
4. Verify the key on the 2nd packet (optional)



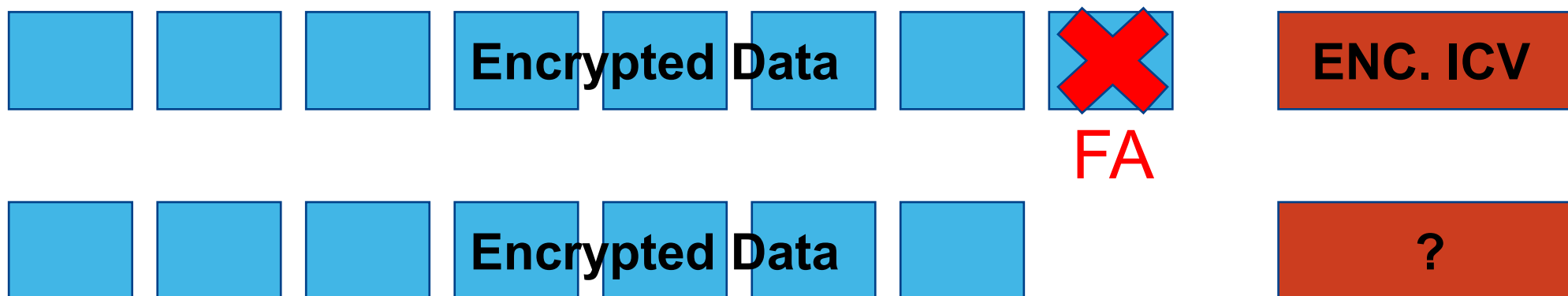
Common Attacks: The FMS Attack

- 2001 – Fluhrer, Martin and Shamir found a class of RC4 keys called “weak keys”
- If the first 2 bytes of enough key stream are known -> The RC4 key is discovered
- The first 8 bytes of WEP packet is a known SNAP-SAP header
- AirSnort implements this attack
 - Recovers key after 20,000 packets = 11 seconds

Common Attacks: The Chopchop Attack

- Does not recover the key, it just reveals the message
- Exploits an ICV vulnerability
- Steps:
 - Capture one packet
 - Truncate the last byte and try to guess one “value” for plaintext
 - Correct the checksum and send packet to AP
 - If guess is correct the AP will reply
 - Repeat until all bytes are decrypted

KoreK Chopchop Attack Illustrated



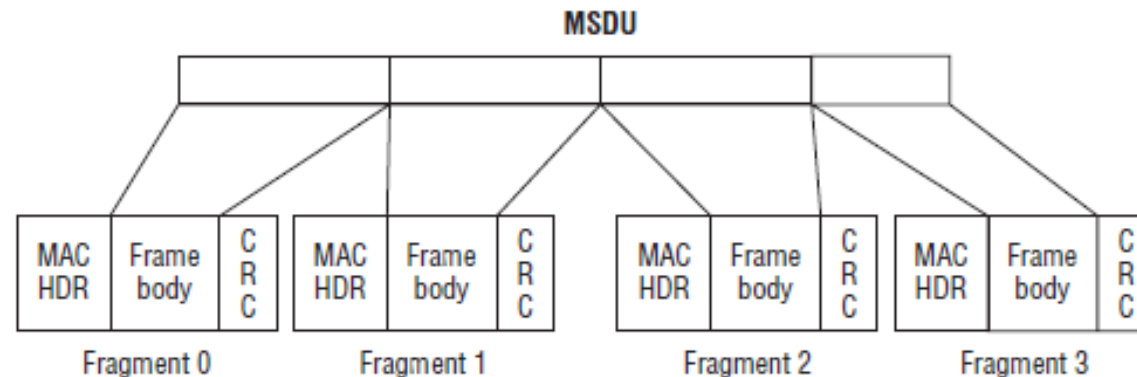
- Guess the value of the deleted byte and calculate new ICV

Guess	New ICV	Accepted?
00	ICV-1	No
01	ICV-2	No
...	...	...
FA	ICV-n	Yes!

Common Attacks: The Fragmentation Attack

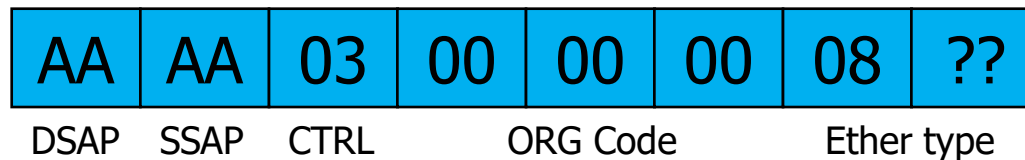
- Fragmentation means chopping a packet into smaller packets
 - Increases the traffic but improves performance in the presence of noise
- 802.11 and IP protocol allow fragmentation
- 802.11 allows for at most 16 fragments
- **This feature can be used for breaking WEP!**

FIGURE 6.5 Fragmentation of an MSDU



Fragmentation Attacks, Basics

- During fragmentation, WEP encryption is performed independently on each individual fragment using the same IV.
 - Possible to send multiple fragments (16) using the same key stream
- You know more about the plaintext than you think you know.
 - Almost all encrypted data packets have a LLC/SNAP header, 8 bytes



Can be either
IP or ARP

- XOR gives 8 bytes of the key stream
- At this point, arbitrary data of $(8 - 4) \cdot 16 = 64$ bytes (4 byte CRC tag) may be sent

Protecting WEP

- Increase the number of bytes used for encryption (“protects” against FMS attack)
- Remove the weak IV - keystream re-use vulnerabilities
- Prevent key re-use
- Extensible Authentication Protocol (EAP) – change often the WEP-key
- Deploy Intrusion Detection Systems (IDS) to protect against injected traffic
- Companies sell hardware using modified versions of the WEP protocol claiming to be secure

Conclusions

- WEP has a long history of vulnerabilities and “fixes”
- WEP is a good example of how attacks evolve and mature over time
- Attacks that a few years ago took days, now take minutes if the right tools are used
- 2005 WEP is officially declared deprecated by IEEE 802.11 committee
- 2008 WEP used by 30% of users in a US university
- Today – too many old networks, some using WEP
- WEP must be abandoned once and for all, rather than patch it yet again !!!